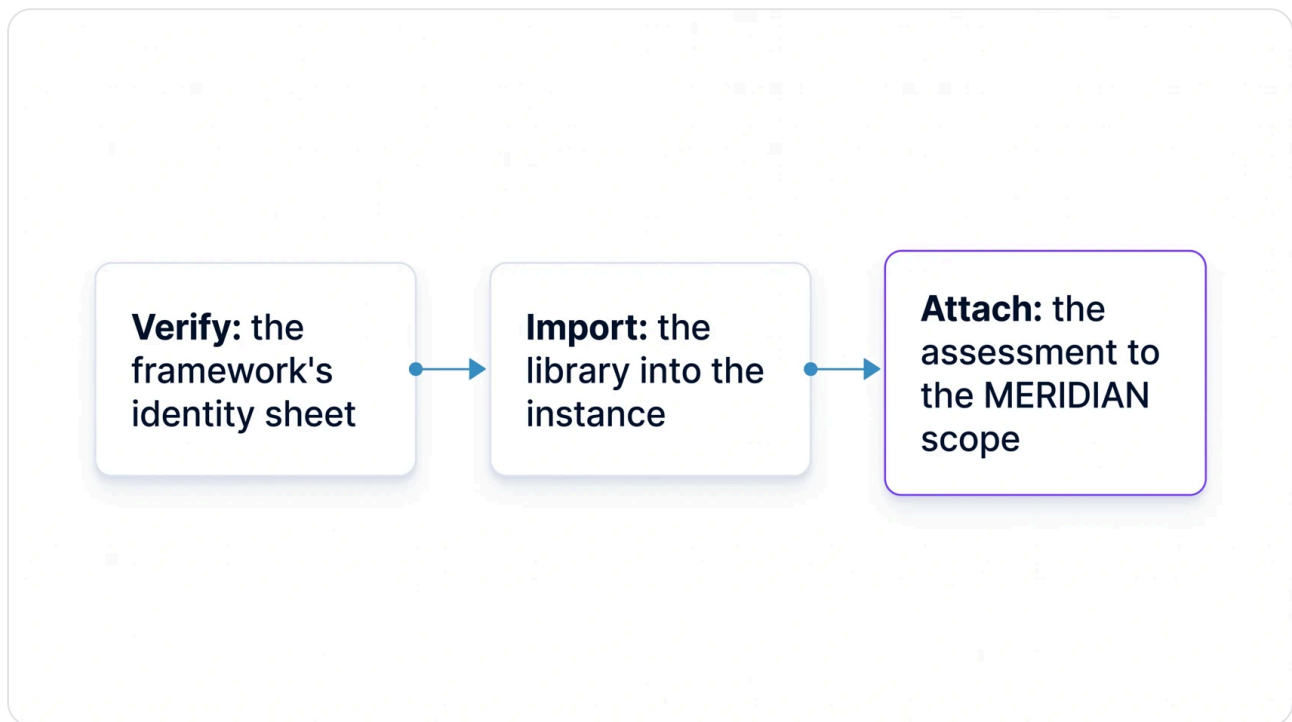


Qualifying and importing the framework into the tool

Objective: a framework installed, verified, and attached to the group's file



A useful framework is verified, imported, then attached to the group's existing work: nothing gets recreated.

Session objectives

By the end of this lab, the working group's instance in the GRC tool contains: the library of the framework chosen at midday, ISO/IEC 27001:2022, imported and visible; a compliance assessment created against this framework and attached to the MERIDIAN scope built in session 2; and the framework's identity sheet, filled in and added to the group's file. What is also learned here:

- **Verify** the identity of a framework before any use: publisher, version, vintage, scope, status
- **Distinguish** what the module calls "qualifying a framework" from qualification in ANSSI's sense, which is a reserved label
- **Explain** what a data import really does, and what it does not do
- **Recognize** in the tool's library the frameworks from this morning's overview, and sort them by family

Prerequisites

- The working group's CISO Assistant instance, in place since session 2, with the MERIDIAN scope, its business assets and its supporting assets already entered: this entire lab plugs into it, nothing gets recreated.
- The framework choice argued in the tutorial: the group's backbone, ISO/IEC 27001:2022, and the grid that justifies it.
- The overview from the lecture: the four families of frameworks, to be found again on screen.

A one-sentence reminder, since the tool returns: CISO Assistant is the GRC software, governance, risk and compliance, adopted by the group in session 2 to carry the mapping; today it gains its second job, carrying the frameworks and the compliance assessments.

Verify before importing: the framework's identity sheet

The title of this sequence speaks of "qualifying" the framework, and this word deserves a pause before any clicking, because it means two very different things depending on who is speaking, and the confusion is a real trap in interviews as in committees.

In this module, qualifying a framework before import simply means: **verifying its identity**. The problem this gesture avoids is banal and costly: teams working for six months against an old edition of a standard, an unofficial translation, or a truncated document found on a third-party site. A framework expires, gets amended, exists in several languages and sometimes in several national variants: before making it the group's yardstick, its identity sheet is established, exactly as the provenance of an executable is checked before installing it. The mechanics come down to six questions: who publishes it, which edition and which vintage, which amendment if any, which scope of application, which status for us, mandatory or voluntary, and which download source is authoritative. The limit of the gesture: the sheet establishes that the work is being done on the RIGHT document, it says nothing about the relevance of the choice, which was the tutorial's job.

At ANSSI, the same word means something else entirely, and one must know how to say it: **qualification is an official label**, issued by the agency to security products and service providers. In the agency's words: « La qualification d'un produit ou d'un service atteste du niveau de sécurité du produit ou du service, du niveau de conformité du produit ou du service aux exigences de l'ANSSI et du niveau de confiance dans le fournisseur du produit ou du service. » (the qualification of a product or service attests to the security level of the product or service, to the level of conformity of the product or service with ANSSI's requirements, and to the level of trust in the supplier of the product or service.) Qualified products and services carry the Visa de sécurité ANSSI, and this label conditions access to sensitive markets, government and operators of vital importance first among them. The boundary to remember: ANSSI qualifies products and providers; nobody "qualifies" a framework in the ANSSI sense, and least of all themselves. If a supplier says "our solution is qualified", it can be checked in the agency's catalogues; if a colleague says "I qualified the standard", they mean, as here today, that they verified its identity. Two sentences, two worlds.

In this module: verifying identity

Publisher, edition, year,
scope, status, source

In the ANSSI sense: an official label

Security Visa, products
and service providers

Two sentences, two worlds: one verifies the identity of a framework, ANSSI qualifies products and providers.

Exercise 1: establish the group framework's identity sheet (10 minutes)

The expected output: the identity sheet of ISO/IEC 27001:2022, on this model, drawing on the morning's lecture and on what the library screen will display shortly.

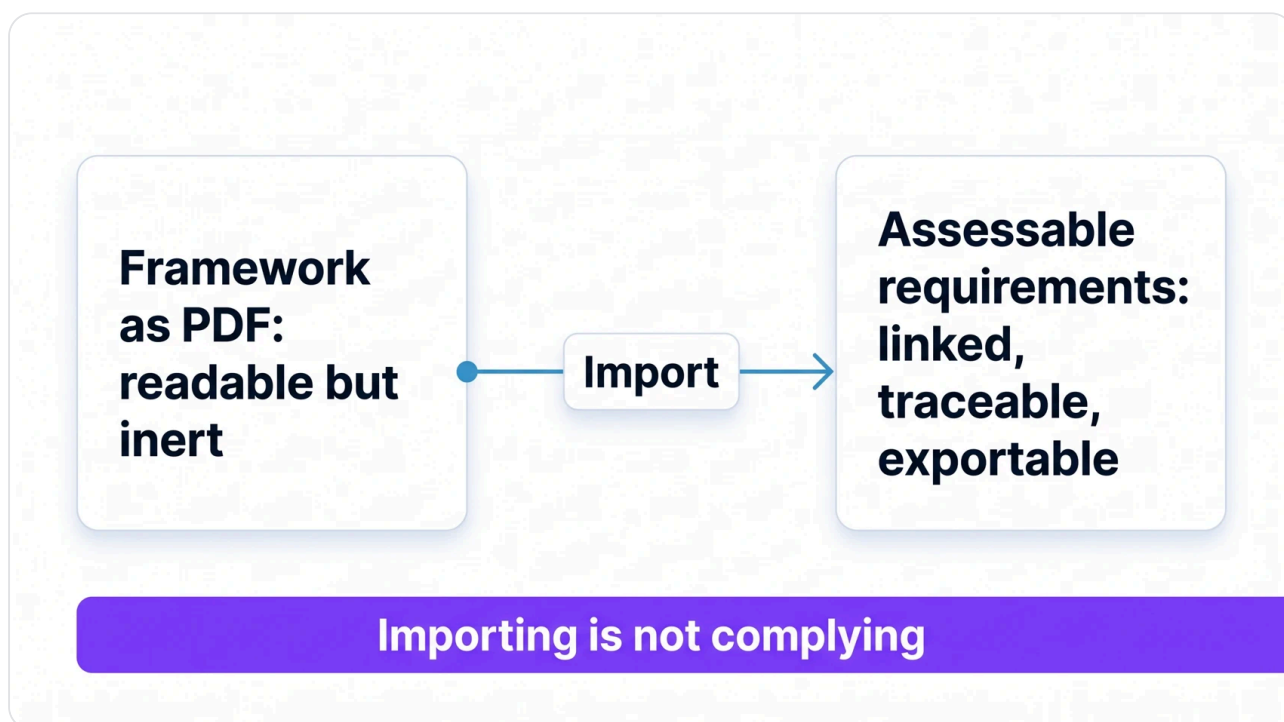
FIELD	TO BE FILLED IN
Exact name and publisher	...
Edition and publication date	...
Amendment in force	...
Official French title	...
Status for MERIDIAN (mandatory / voluntary, and why)	...
What the sheet does not say (one line of honesty)	...

1. **Complete** each field, writing only what can be justified by a source from the morning or by the tool's screen.

2. **Justify** the "status" field in one sentence that distinguishes what is true today from what will become true once the transposition law is promulgated.
-

The import: what the instance must contain at the end

Second stage, the central move. But first, understanding it, because "import" is one of those tool words used without thinking. The problem the import solves: a framework living in a PDF is inert, it can be read but nothing in it is actionable; every assessment starts over from a home-made spreadsheet, like the tracking tool annexed to the hygiene guide, useful but solitary. **Importing data**, properly understood, means converting external content, here the complete structure of a framework, into native objects of the tool: each requirement becomes a record, linked to its neighbours, assessable, traceable, exportable. The mechanics in CISO Assistant: frameworks are delivered as ready-to-import libraries, packaged with the application; the import reads the library and creates the corresponding requirement tree in the instance. The limit, and it is worth stating solemnly: importing is not complying. After the import, the instance contains the LIST of requirements, not their satisfaction; the group's compliance percentage will not move by a single point because the standard has entered the tool. The import installs the yardstick, the measurement work starts afterwards, and its big appointment is the session 4 audit.



The import installs the yardstick in the tool, it measures nothing: compliance remains entirely to be demonstrated.

Exercise 2: import and prove the import (15 minutes)

1. **Locate** in the list of libraries the one named "International standard ISO/IEC 27001:2022", provided by ISO/IEC and packaged by the tool's publisher; the instance offers more than two hundred, searching by name is a must.
-

2. **Import** this library into the working group's instance.

3. **Prove** the import by recording three numbered observations, to be written on the sheet: the total number of assessable requirements created, the number of controls in the Annex A block, and the distribution of these controls across the four themes.

Validation criteria, to check by oneself before calling the instructor: the framework appears in the instance's list of active frameworks; the tree shows two blocks, the clauses numbered 4 to 10 on one side, Annex A on the other; the three readings give 123 assessable requirements in total, including 93 Annex A controls distributed as 37, 8, 14 and 34 across the organizational, people, physical and technological themes. If the counts differ, do not brush past it: either the import is incomplete, or a different library was imported, and both are fixed in two minutes now, in two days at audit time.

Worth noticing in passing, the name the tool gives the Annex A block: « Déclaration d'applicabilité » (Statement of Applicability, SoA). To note without dwelling on it: this document, which decides control by control what applies to the group, is the great work of session 8, and it only makes sense after the risk analysis. Today, it is just a label on the screen.

An import can be redone: when in doubt about what the instance contains, it is always better to observe, correct and re-import now than to discover in session 4, in front of the audit, that the yardstick was the wrong one. The tool is a sandbox before it is a register.

Attaching the framework to the group's work

An imported but orphaned framework serves no purpose: the third move connects it to what MERIDIAN has already built.

Exercise 3: create the group's compliance assessment (15 minutes)

1. **Create** a compliance assessment backed by the imported framework, attached to the MERIDIAN scope created in session 2, and named according to the group's convention: "MERIDIAN - ISO/IEC 27001:2022 - initial assessment".

2. **Browse** the assessment's tree to check that it does reproduce the framework's two blocks, without assessing any requirement: the assessment stays blank today, that is its normal state.

3. **Spot**, without scoring anything, three requirements that the work of sessions 1 and 2 already satisfies at least partially, and note for each one the existing deliverable that would serve as its evidence (hint: start from what the group already owns, rather than from what it lacks).
-

Validation criterion: the instance shows a compliance assessment linked to the MERIDIAN scope and to the framework, in its initial state, and the sheet carries three requirement-deliverable pairs. This little spotting exercise is not decorative: it is the exact starting point of next session's audit, which will systematically walk through what has just been skimmed, and these three pairs will be the first three pieces of evidence.

The whole landscape fits in the library

Last stage, short and deliberately contemplative: the tool's list of libraries is a map of the world of frameworks, and this whole day will have served to learn how to read it.

Exercise 4: recognize and sort (10 minutes)

1. **Find** in the list of libraries the following four entries, without importing them: "ANSSI - Guide d'hygiène informatique"; "Digital Operational Resilience Act (DORA)"; "HDS v2.0"; "Référentiel Général de Sécurité 2.0 - Annexe B2".
 2. **Sort** each one into a family from the morning's overview, noting the displayed publisher and one line of justification.
 3. **Observe** an absence: search for the ReCyF in the list. Explain in two sentences why it is normal not to find it there, drawing on its status and its publication date (hint: compare what a software publisher does at each version with what ANSSI does at each publication).
-

Answer keys and assessment criteria

Answer key for exercise 1: the expected sheet

Exact name: ISO/IEC 27001:2022, published by ISO and IEC, the international standardization organizations. Edition: the third, published on 25 October 2022. Amendment: Amd 1:2024. Official French title: « Systèmes de management de la sécurité de l'information – Exigences ». Status for MERIDIAN: voluntary today, chosen by the group as its backbone by a reasoned decision in the tutorial; it will remain voluntary after the promulgation of the transposition law, but a certification will then be able to serve as an acceptable means of compliance for the governance objective of the French framework, over the certified scope, which changes its value without changing its status. Expected line of honesty, for example: the sheet establishes the identity of the document, not the group's capacity to implement it, nor its cost.

Answer key for exercise 3: three defensible pairs

Any reasoned answer is admissible; here are three solid pairs. The context and understanding-the-organization requirements find their starting point in the session 2 mapping, business assets and supporting assets per subsidiary. The roles and responsibilities requirements rest on the RACI matrix and the governance scoping note from session 1. The asset inventory controls of the organizational theme of Annex A find their evidence in the prioritized inventory and the Top 5 of critical assets from session 2. For any other proposed pair, the marking criterion is single: does the cited deliverable actually exist in the MERIDIAN file, and does it cover at least part of the letter of the requirement?

Answer key for exercise 4: the sorting and the absence

LIBRARY	DISPLAYED PUBLISHER	FAMILY	JUSTIFICATION
ANSSI - Guide d'hygiène informatique	ANSSI	Authority guide	Recommendations without binding force, a quasi-official reference
Digital Operational Resilience Act (DORA)	EU	European regulation	Directly applicable, finance sector-specific, moot for MERIDIAN today
HDS v2.0	Agence du Numérique en Santé	French sector-specific certification	Targets health data hosting providers, to be required of the Santé subsidiary's providers
Référentiel Général de Sécurité 2.0 - Annexe B2	ANSSI	French regulatory framework	Adopted pursuant to the 2005 ordinance, the environment of Territoires' clients

The absence of the ReCyF, finally: the instance's library is the one packaged with the software version deployed for the module, and this version predates the publication of the ReCyF, circulated as a working version in March 2026. A piece of software embarks the world as it was at its build date; it is a lesson about tools as much as about regulation, and one more reason to keep an identity sheet: the tool has a vintage too.

Self-assessment grid

CRITERION	VALIDATED IF
Identity sheet	Six fields filled in, status justified by distinguishing today from after promulgation
Import	Framework active, two blocks visible, the three readings matching the expected values
Compliance assessment	Created, attached to the MERIDIAN scope, blank, three requirement-deliverable pairs noted
Sorting	Four libraries found and sorted with publisher and justification, the absence of the ReCyF explained by the tool's vintage
Tool discipline	No session 2 object recreated or modified: the lab plugged into the existing work